

Ch3_Information System Risk

Information System

What?

1. System?

A system is a group of interacting or interrelated elements that act according to a set of **rules** to form a unified whole.

2. Information System

- Organized combination of **people, hardware, software, communications networks, data resources, and policies and procedures.**
- Store, retrieve, transform, and disseminate **传播 information**
 - Communication network: a system of interconnected **nodes**, these networks rely on wired or wireless connections.

Data Transmission:
Information is sent between nodes, often using protocols like TCP/IP, through methods such as packet switching or circuit switching. 

Fundamental **Roles of IS 作用**

- Support of business processes and operations.
- Support of decision making by employees and managers.
- Support of strategies for competitive advantage.

Support of business processes and operations 日常业务流程与运营

Support of decision making by employees and managers 信息系统提供数据分析、报表、预测模型，帮助做出明智决策

- 销售趋势分析
- 客户行为预测

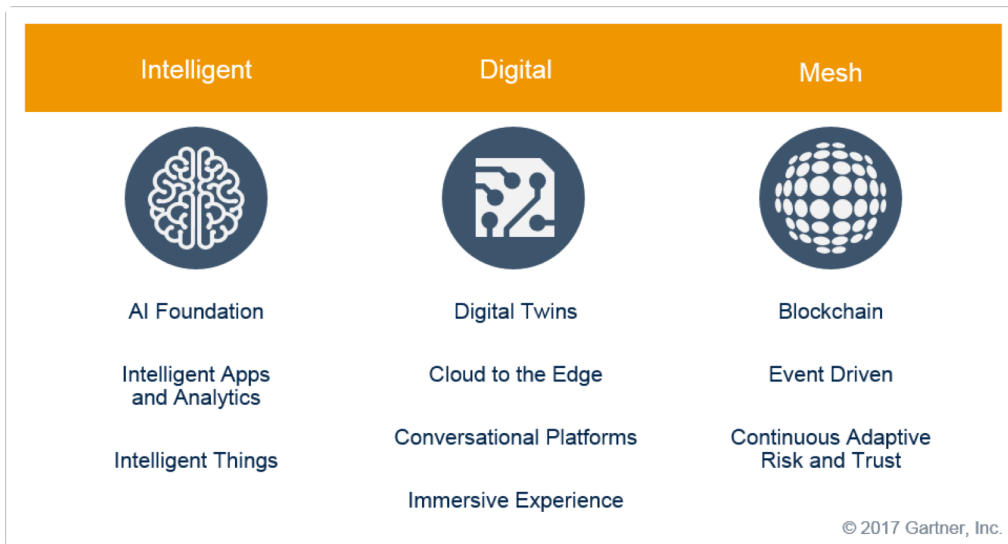
Support of strategies for **competitive advantage** 信息系统不仅是工具，更是战略武器

- 亚马逊用算法优化物流与推荐系统
 - Amazon uses **big data** and **machine learning algorithms** to optimize warehouse layout, delivery routes, and inventory management, improving logistics efficiency.
 - Its recommendation system analyzes user behavior and purchase history to deliver

personalized product suggestions, increasing conversion rates and customer satisfaction.

- 教育平台用AI个性化学习路径
 - Educational platforms use **AI models** to analyze student responses, interests, and knowledge mastery to dynamically **generate personalized learning paths**.

Technology Trend



1. Digital Twins

A digital twin is a virtual representation of a physical object, system, or process that enables real-time monitoring, analysis, and simulation. Digital twin technology integrates engineering data, geospatial data, IoT inputs, and operational data into a unified, federated environment.

- 数字孪生是对物理对象的数字化映射或虚拟复制。
- 我们可以在数字孪生中进行模拟、测试与优化，而不直接影响物理对象。
- 一旦在数字孪生中验证了方案的可行性，我们可以将其应用于物理对象，实现精准调整。

2. Cloud to the Edge

Edge to cloud refers No longer confined 限制 to the data center;

It is being generated at the **edge** in ever-growing amounts, processed and stored in the cloud, and used by an increasingly distributed global workforce.

Why to use edge-to-cloud?

Edge-to-cloud computing enables organizations to avail the benefits of edge computing and cloud infrastructure, facilitating real-time decision-making and boosting system performance.

- **Reduced latency:** The edge-to-cloud architecture processes data nearer to the source instead of transferring data to the cloud for processing. This closeness reduces the distance needed to send data to the processing infrastructure. Data is processed locally to get insights and make decisions, lowering latency associated with transferring data to the cloud and processing it further.
- **Increased security:** The data accumulated at the edge is stored in the same location, enabling enterprises to adhere to privacy, compliance, and governance standards. It is easy to implement security policies to minimize risks. Since the data is stored locally, it is less susceptible to security breaches.
- **Improved scalability:** The distributed architecture enables enterprises to scale their edge computing resources as needed to facilitate parallel processing and improve scalability.
- **Enhanced reliability:** Multiple edge nodes reduce the risk of failure of single points. If an edge device stops working, the workload is shifted to other devices to reduce downtime and ensure continuity of operations.
- **Reduced costs:** Processing data locally instead of in the cloud lowers the IT investments of an organization by cutting down the transmission and storage costs.

3. Immersive Experience – VR, AR

增强现实 (AR) 将数字内容叠加到现实世界，增强您对现实世界的感知，

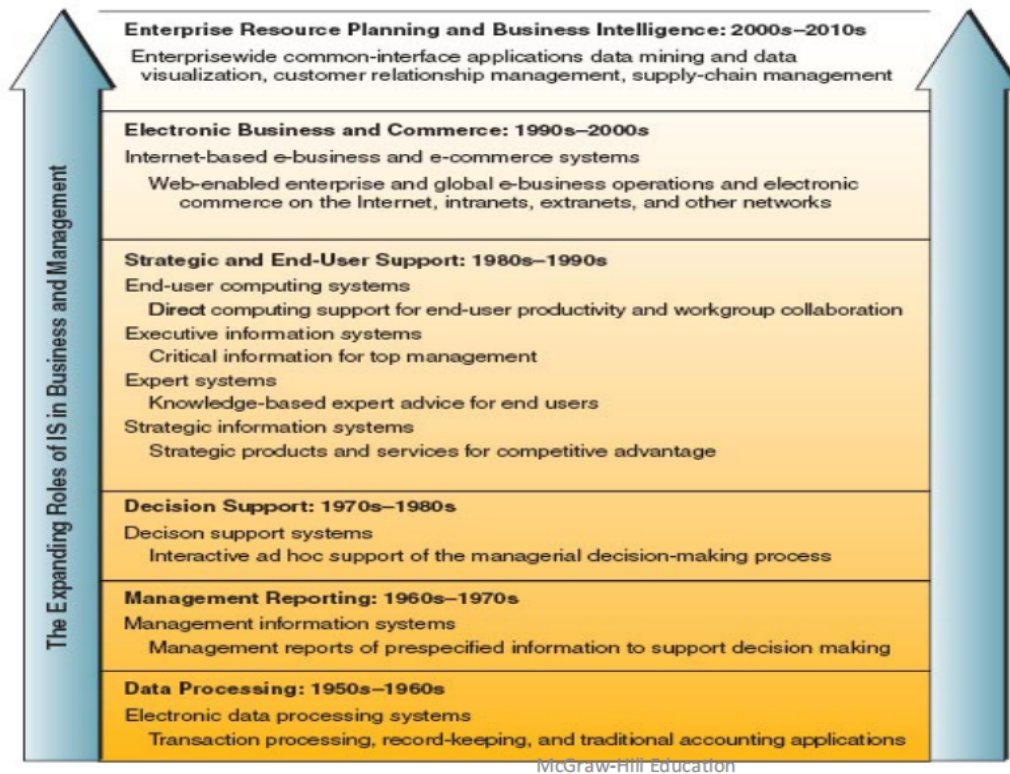
而虚拟现实 (VR) 则让您完全沉浸在完全模拟的数字环境中，使您与物理世界脱节

4. Blockchain

区块链是一个去中心化的分布式数据库，数据存储在多台计算机上，具有防篡改功能。

加密哈希值使得几乎不可能在不更改所有后续区块的情况下更改任何区块，从而确保整个流程的完整性。

Trend in Information System



Data Processing – 电子数据处理系统，用于事务处理、记录保存与会计应用

Management Reporting – 信息开始服务于管理层，但仍以静态报表为主

Decision Support – 信息系统开始具备分析与模拟能力

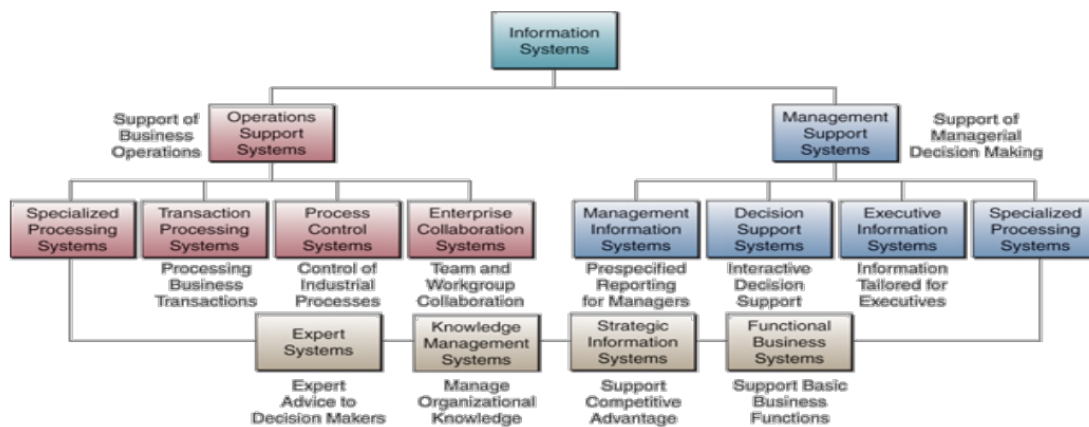
Strategic and End-User Support – 信息系统开始支持竞争优势、协作与知识管理

- 终端用户计算系统、战略信息系统、群体决策支持系统

Electronic Business and Commerce – 信息系统进入互联网时代，支持全球化与在线交易，企业运营与电子市场，数字商品交易

Enterprise Resource Planning & Business Intelligence – 企业级统一界面应用、数据挖掘、数据可视化、客户关系与供应链管理

Types of Information System



1. 支持业务运行

专业处理系统	Specialized Processing Systems	针对特定任务或行业的自动化处理系统
事务处理系统	Transaction Processing Systems	处理日常业务交易，如银行转账、订单处理
过程控制系统	Process Control Systems	控制工业流程，如制造业的自动化生产线
企业协作系统	Enterprise Collaboration Systems	支持团队协作与工作组沟通，如企业内部聊天、共享文档平台

2. 支持管理决策

管理信息系统	Management Information Systems	提供预设报表，支持管理层日常决策
决策支持系统	Decision Support Systems	提供交互式分析工具，辅助复杂决策
高层信息系统	Executive Information Systems	为高层管理者定制的信息摘要与趋势分析
专业处理系统	Specialized Processing Systems	在管理层面用于特定分析任务

Information systems combine:

- Operations Support Systems
 - Transaction Processing systems
 - Process Control Systems
 - Enterprise Collaboration Systems
- Management Support Systems
 - Management Information Systems
 - Decision Support Systems
 - Executive Information Systems
- Other Systems
 - Expert Systems
 - Knowledge Management Systems
 - Strategic Information Systems

How does an expert system work?

Modern expert knowledge systems use [machine learning and artificial intelligence](#) to simulate the behavior or judgment of domain experts. These systems can improve their performance over time as they gain more experience, just as humans do.

IS Risk

Four perspectives for Information System Risk

- Business disruption
- Relational risk
- Technology risk
- IT governmentt risks

1. Business disruption

业务中断是指公司正常运营的**内部中断**，或者更常见的是，an external market shift caused by disruptive innovation that challenges existing products or business models。它可能源于技术进步、市场趋势变化，或自然灾害或网络攻击等意外事件

From **external** sources

扰乱：闯入

Face by **physical threats** (flood, fire, etc.), **intrusion** (e.g. hackers), or **functional failure** (inaccurate data, reporting system not providing required information to management)

2. Relational risk

Relational risk refers to the potential for harm, conflict, or loss of trust within relationships due to factors like poor communication, misalignment of goals, or negative interactions, which can lead to damaged relationships and missed opportunities. It can also involve taking a personal risk to share vulnerability or express a differing opinion in the hope of fostering growth and deeper connection. 

n. (公司、组织或军队中的) 全体人员, 员工; 人事部门

n. 供应商, 销售商

Occur between IT personnel and vendors, third parties or other parts of the enterprise.

More a function of human interaction

更多是人与人之间的互动。

3. Technology risk

- 系统能否真正响应企业需求 response to enterprise needs
- 是否符合内部与外部通信标准
- 是否具备良好的IT维护与项目管理流程 Sound information technology maintenance and project management procedures
- 技术风险关注的是系统本身的功能性、兼容性与维护能力

4. IT governance risks IT治理风险

- Relate to strategy
- IT resources
- Compliance or legal issues

IT治理风险关注的是信息系统如何与企业战略、资源管理和法律合规相结合。

Application of IS Risk Management

COSO(组织) Application

COSO框架是一套用于设计、实施和评估组织内部控制以实现运营、报告和合规目标的指南

COSO involves a risk management framework including the following steps

- 1. Internal Environment
- 2. Objective Setting
- 3. Event Identification
- 4. Risk Assessment
- 5. Risk Response
- 6. Control Activities
- 7. Information and Communication
- 8. Monitoring



Internal Environment	建立风险管理文化，包括价值观、风险偏好、治理结构与责任分配。强调领导层的态度和组织氛围。
Objective Setting	明确企业战略目标，并确保这些目标与风险管理活动一致。
Event Identification	识别可能影响目标实现的事件，包括机会与威胁。
Risk Assessment	分析事件的可能性与影响，进行定性或定量评估，绘制风险矩阵，确定优先级。
Risk Response	针对每个风险选择应对策略：规避、转移、缓解或接受，并制定具体行动计划。
Control Activities	实施控制措施
Information and Communication	确保相关信息在组织内部和外部有效传递，支持风险管理决策。
Monitoring	持续监督风险管理体系的运行效果，及时调整策略。包括内部审计、KPI跟踪、反馈机制等。

IS Risk Identification and Analysis

这一方法更偏向项目管理与风险控制，关注的是在项目启动前或执行中如何识别、评估并应对潜在风险。

- **Risk Identification**

what is the most important thing for your company?

- *focus on identify and rank project elements, project goal and risk.*
- *Pre-project planning and research.*

Identify project elements	包括任务、资源、时间节点等关键组成部分
Identify project goals	确保团队对目标有一致理解
Identify potential risks	找出可能影响项目成功的因素
Pre-project planning & research	在项目开始前进行信息收集与分析
Rank risks	按影响程度或发生概率对风险进行优先级排序

- **Risk Analysis**

- *Supported by quantitative techniques or qualitative approaches based on judgment.*

- **Risk Control**

- *Activity of measuring and implementing control to avoid the impact of risk elements.*
- *Proactive resources to deal with problem before they occur.*

- **Risk Reporting**

- *Communication identified risks to others for discussion and evaluation.*

The system failure method 系统性分析失败的方法流程

这一方法强调从系统结构与运行机制出发，逐步识别失败原因。 事后分析

- *Pre-Analysis : define purpose, perspectives, gather source material*
- *Identify significant failures and select systems*
- *Modeling: clarity the nature of the system*
- *Comparison: gain understanding*
- *Analysis*
- *Synthesis*

英文名称	说明	Comparison 在系统分析中的具体任务
Pre-Analysis	明确分析目的、视角，并收集相关资料	1. 与正常状态对比 - 当前系统 vs. 正常运行时的行为 - 例如：失败时的数据流是否异常？响应时间是否延迟？
Identify Failures and Select Systems	找出关键失败点，并确定要分析的系统	2. 与行业标准对比 - 当前配置 vs. NIST、ISO、COSO等标准 - 例如：是否缺少关键控制点？是否违反最佳实践？
Modeling	描述系统结构与运作方式，澄清系统本质	3. 与历史版本对比 - 当前系统 vs. 过去版本或升级前状态 - 例如：新版本是否引入了不兼容的模块？
Comparison	对比不同系统或状态以加深理解	4. 与替代方案对比 - 当前架构 vs. 其他可能设计（如云部署 vs. 本地部署） - 例如：是否有更稳定或更安全的替代方案？
Analysis	深入探讨失败原因、影响与机制	
Synthesis	整合分析结果，提出改进建议或新设计	

- Identify significant failures:** 识别出哪些失败是关键的、值得深入分析的
- Select systems:** 从多个相关系统中，选出那些与失败最相关的系统，作为分析对象

建模在系统失败分析中的作用

1. 澄清系统边界

- 哪些部分属于系统？哪些是外部依赖？

2. 识别关键流程与节点

- 哪些流程是核心？哪些节点可能是失败源头？

3. 揭示因果关系与依赖结构

- 哪些组件之间存在强依赖？是否存在单点故障？

事后分析工具

系统失败分析中的三个关键维度：控制机制（System Control）、通信机制（System Communication）和人的责任结构（Human Aspects of System）。

The system failure method

System failure approach can be applied to analyze all types of systems:

- System control:** Control is action to reach or maintain a desired state. Monitor the output of the system.
- System communication:** Many systems failures due to problem with communication link between system components.
- Human aspects of System:** Part of understanding the system is to identify the structure of responsibility – who is responsible for what.



如果控制失效，系统可能偏离目标，导致错误积累或功能失常。

如果通信中断或误解，就可能导致数据丢失、功能冲突或响应延迟。

如果责任不清，问题出现时没人处理，或者处理不当，系统就容易失败。

失败的原因

Failure of systems is commonly a result of:

- *Deficiencies in organization structure and lack of performance control*
- *Lack of a clear statement of purpose*
- *Subsystem deficiencies*
- *Lack of effective communication between subsystems*
- *Inadequate design*
- *Insufficient consideration of environment and insufficient resources*
- *Imbalance of resources and inadequate testing*

Subsystem deficiencies – 子系统存在缺陷
